



Procedure No: EXP202207418 (PS/0680/2022)

RESOLUTION OF THE SANCTIONING PROCEDURE

From the actions carried out by the Spanish Agency for Data Protection and based on the following:
BACKGROUND

FIRST: On 11/06/22, Ms. A.A.A. (hereinafter, the claimant) filed a complaint with the Spanish Agency for Data Protection against the entity HOLALUZ-CLIDOM, S.A., CIF: A65445033 (hereinafter, the defendant or CLIDOM), for the alleged violation of data protection regulations: Regulation (EU) 2016/679 of the European Parliament and of the Council, of 27/04/16, regarding the Protection of Natural Persons with regard to the Processing of Personal Data and the Free Movement of such Data (GDPR), and Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (LOPDGDD).

The complaint is expressed in the following terms:

"On April 7, 2022, I see a charge in my account of ***AMOUNT.1 from a light company that I did not know (more than double what I usually pay) and I return the receipt as I think it is a scam. Immediately, I call the real estate agency and ask them if they know anything about this, and they tell me that yes, that it is a massive change they have made to all tenants so that the electricity is in our name. I respond that I have not been informed of this change and much less have I given my consent for them to change my company and make a contract in my name.

I exchange a series of emails with them, in which they always claim that it is a legal practice (which may be) but what I tell them is why they did not notify me of the change and why they did not wait for my consent. I comment that I pay the proportional part of what I have been paying until now and they do not respond to that.

I called Holaluz commenting on the incident and asking for the electricity contract that I supposedly had signed, and they sent me the contract, then it was when I saw that it had been signed on my behalf, without my consent, by a certain B.B.B."

The complaint is accompanied by the following documentation:

- Copy of the lease agreement dated 24/05/21, where Mr. C.C.C. is listed as the landlord and Ms. A.A.A. as the tenant, for the property located in Madrid, ***ADDRESS.1. In this contract, Mr. D.D.D. is listed as the verbal representative, residing at ***ADDRESS.2.
- o Of the clauses of the contract, Clause No. 5 "EXPENSES" is relevant to the present case, which states: "The expenses related to the consumption of electricity, water, and telephone shall be borne by the Tenant, as well as any other communication or television service contracted by the Tenant."
- Copy of the exchange of a series of emails that took place on 11/04/22, between the tenant and the representative of the real estate agency ENFOKA, where the tenant requests explanations as to why she was changed to a different electricity company without her consent and her desire to return to the previous electricity company (Iberdrola).
- In the Particular Conditions of the new electricity supply contract with CLIDOM, the following can be read, among others:
 - o Customer Data: A.A.A.; NIF: ***NIF.1; Phone: ***PHONE.1; Address: ***ADDRESS.1; e-mail: ***EMAIL.1. Bank account: (...).
 - o Data of the contract signer: B.B.B. NIF: ***NIF.2 Contract date: 24/02/22.

SECOND: On 08/07/22, in accordance with the provisions of Article 65.4 of the LOPDGDD, this Agency forwarded the complaint to the real estate agency, ENFOKA SISTEMAS GLOBALES, S.L. (ENFOKA) and to the electricity retailer, CLIDOM, for them to analyze it and report back within one month on what was stated in the complaint.

THIRD: On 21/07/22, the real estate agency ENFOKA sent this Agency a response to the request made, in which it states, among other issues, that in compliance with the provisions of the LAU and the lease agreement, the tenant was urged on numerous occasions to modify the electricity supply, all of which were unsuccessful. Therefore, in February, an email was sent informing her of the change of company and communicating the tenant's data to the company Runup Business, S.L. (QLIP), belonging to the external customer acquisition channel of CLIDOM.

FOURTH: On 09/08/22, the entity CLIDOM sent this Agency a response to the request made, in which it states, as relevant data, the following:

- That, according to CLIDOM's database, the claimant is registered with the company with the CUPS1 (...), ***ADDRESS.1 from 26/02/22 to 31/03/22. This registration was carried out by the commercial channel Run Up Business SL with which CLIDOM has a contractual relationship.

The sales representatives are authorized to subcontract any other persons or companies to provide the services. In this case, it is noted that the subcontracted company was ENFOKA Sistemas Globales, S.L. and that due to the collaborator's appearance of the veracity of the hiring, it could not be detected, until the claimant indicated it, that this hiring had been carried out without her consent.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/32

- That CLIDOM randomly conducts a subsequent review of the quality of calls and registrations made by new collaborators, through a review protocol of a certain percentage of the registrations where CLIDOM ensures that customers have indeed shown their consent to change service providers or to register for supply.

- That the introduction of the Customer's personal data was carried out by a third party who failed to comply with the established contractual obligations, being the same responsible for any harm arising from the breach.

Along with the response document, the entity CLIDOM attaches the following documentation:

- Promotion Contract for "Electricity and Natural Gas Supply Contracts" between CLIDOM and QLIP, dated 24/08/21.

FIFTH: On 11/09/22, the Director of the Spanish Agency for Data Protection issued an agreement admitting the processing of the complaint presented, in accordance with Article 65 of the LPDGDD, upon noting possible rational indications of a violation of the regulations within the scope of the competencies of the Spanish Agency for Data Protection.

SIXTH: On 26/01/23, the Director of the Spanish Agency for Data Protection initiated sanctioning proceedings against the entity CLIDOM, upon noting reasonable indications of a violation of the provisions established in Article 25 of the GDPR, imposing an initial fine of 100,000 euros (one hundred thousand euros). Furthermore, as measures to be implemented, it was indicated that, in the resolution adopted, this Agency could require the entity to adapt the processing operations it carries out to the regulations on personal data protection and the procedure through which individuals provide their consent for the collection and processing of their personal data.

SEVENTH: On 15/02/23, the entity CLIDOM submitted a written statement of allegations regarding the initiation of the file in which it states, as data to be taken into account, the following:

- That, regarding the possible violation of the principle of data protection, while it is true that CLIDOM responds and identifies with the definitions referred to the data controller in Articles 4 and 24.1 of the GDPR, it does so in relation to the contractual relationship that exists with QLIP, for the purposes of the service contract signed with it on 24 August 2021 for the provision of promotional services for electricity supply contracts and the recruitment of potential customers.

- That the contract signed between the two parties, CLIDOM, as the data controller, included, as a contractual obligation for QLIP, in its capacity as data processor, the proactive responsibility to collect the consent of the data subjects in accordance with the requirements of the GDPR, and therefore, it is the Collaborator's responsibility to make the relevant checks regarding the identity of the consumer and their willingness to contract.

- That the sub-processor of QLIP, the real estate agency ENFOKA, acted against CLIDOM's instructions regarding the obligation to obtain the consent of the data subjects as it impersonated the identity of the affected party and also signed invalid consent without being able to comply with the principles of transparency, freedom, and explicit consent, with QLIP being fully responsible for the

negligent actions of its provider.

- That, regarding compliance with the provisions of Article 25.1 GDPR, concerning the application of technical and organizational measures to verify the collection of valid consent for the personal data of the data subjects, CLIDOM has a quality and authentication system regarding the identity of its end customers through a review protocol of a significant percentage of registrations of end users, especially when they come from indirect channels to CLIDOM. Although, due to volume reasons, not all authorizations are requested.

Along with the written allegations, the entity CLIDOM attaches the following documents:

- Promotion Contract for "Electricity and Natural Gas Supply Contracts" between CLIDOM and QLIP, dated 24/08/21.
- Analysis report on the need to conduct an impact assessment, dated 12/09/22.
- Privacy Impact Assessment "Customer Management".
- Controls derived from the privacy impact assessment of the "Customer Management" activity.

EIGHTH: On 06/04/23, the proposed resolution was notified to the entity being complained against, in which it was proposed that the Director of the Spanish Agency for Data Protection proceed to ARCHIVE the present sanctioning procedure against the entity, HOLALUZ-CLIDOM, S.A., CIF: A65445033, in accordance with the provisions of Article 63.3 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), since, as derived from the contractual relationship that exists between CLIDOM and QLIP, it included, as a contractual obligation of QLIP, in its capacity as data processor, the proactive responsibility to collect the consent of the data subjects in accordance with the requirements of the aforementioned GDPR, thus breaching, in this case, the service contract signed with CLIDOM.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/32

NINTH: On 10/07/23, the Director of the Spanish Agency for Data Protection notified the responding party of the granting of a period of fifteen days, in accordance with Article 90.2 of the LPACAP, to present any arguments they deemed necessary in their defense regarding the alleged infringement of Article 25 of the GDPR. It was considered, in this case, that when the service contract was changed in the name of the tenant, CLIDOM did not carry out the necessary checks to verify whether the claimant had consented to the change of electricity company, especially after the contract for the change of company was signed by another person unrelated to the tenant, without any justification of representation, and it is significant that this person belonged to the real estate agency ENFOKA, a subcontractor of the entity QLIP.

TENTH: On 02/08/23, CLIDOM submitted a written statement of allegations in which, among other things, it indicated the following:

"First.- Procedural defect: On April 6, 2023, CLIDOM received a Proposal for resolution of the sanctioning procedure with procedure number EXP202207418 (PS/0680/2022) with the following resolution proposal from the instructor of the procedure: 'That the Director of the Spanish Agency for Data Protection proceed to FILE the present sanctioning procedure against the entity, HOLALUZ-CLIDOM, S.A., CIF: A65445033 in accordance with the provisions of Article 63.3 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), for the alleged infringement of Article 25 of the GDPR. By virtue of this, the above is notified, and the procedure is made known so that within ten working days, they may present any arguments they consider necessary in their defense and submit the documents and information they deem pertinent, in accordance with Article 89.2 in relation to Article 82.2 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations.'

This proposal determined the filing of the sanctioning procedure for the alleged infringement of Article 25 of the GDPR, granting a period of 10 days for CLIDOM to present the appropriate arguments for its defense as well as the pertinent documents. Since CLIDOM was the recipient and was notified of the

same without proceeding to submit allegations, being in agreement with the proposal for the filing resolution, given that it was proven that there was no type of non-compliance on the part of CLIDOM. Article 63.3 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) states the following: 'No new sanctioning procedures may be initiated for acts or conduct classified as infringements in which the offender persists continuously, as long as a first sanctioning resolution has not been issued with executive character.' This is part of a procedural defect regarding the justification for the reopening of the sanctioning procedure notified on July 4, 2023, since, as the article itself states, it will not be possible to initiate a new sanctioning procedure when the procedure that is in processing has not yet been completed. In this specific case, there was reliable notification of the filing of the procedure."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/32

process due to the lack of evidence of the violation of the Data Protection Law after providing all relevant evidence and clarifications, thus leading to the corresponding filing and communication of the proposed resolution.

In response to the present allegation, and in accordance with Article 76 of the LPACAP, CLIDOM submits this written statement of allegations on the grounds of a procedural defect regarding the reopening of the sanctioning procedure without the legal basis alleged by this Administration being duly justified and substantiated, considering that the legal basis claimed by it is based on Article 90.2 of the LPACAP. This article states that "[...] if the competent authority to resolve a procedure considers that the infringement or the sanction is of greater severity than that determined in the proposed resolution, the accused will be notified to provide any allegations they deem convincing within a period of 15 days."

The reopening procedure reiterates the same allegations and provides the same legal grounds that were reflected in the sanctioning procedure filed on April 6, 2023, thus creating legal uncertainty in the filing of the proceedings given that they have already been filed due to the absence of non-compliance by CLIDOM, reflecting the same severity analysis in both procedures. In other words, in both procedures, the Administration reiterates the same grounds, and consequently, maintains the same level of severity that was previously reflected in the proposed resolution procedure, rendering Article 90.2 LPACAP invalid, as a greater severity was not analyzed and concluded in the reopening procedure.

Having stated all of the above, CLIDOM considers and argues that there is a procedural defect in the interpretation of Article 90.2 applied in the reopening sanctioning procedure.

Likewise, analogously for the present case, this party understands that the same reasoning should be applied as for the principle of non bis in idem, which is enshrined in Article 25 of the Spanish Constitution. The principle of non bis in idem, in its application to the sanctioning power of the Administration, establishes that facts that have been sanctioned criminally or administratively cannot be sanctioned again, in cases where there is identity of the subject, fact, and basis. Thus, it imposes the avoidance of duplicity of sanctions for the same facts (STC 2/1981, January 30, 1981).

In its procedural aspect, this principle prohibits the duality of procedures or processes, in the event that the triple identity previously mentioned occurs, which means that, if a sanction is annulled for substantive reasons or for violation of a fundamental right, a new sanctioning procedure cannot be initiated, even if the statute of limitations period is still open (STS 7-3-16, EDJ 16512).

In this regard, the facts that the instructor of the file intends to reopen were included in the written statement of allegations submitted by CLIDOM from C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/32

from which the file of the case was derived. This resolution would violate the principle of non bis in

idem because it assigns the archived content to a new case file, which encompasses the same facts that were the subject of the previous process and which had already been ruled out as potentially constitutive of an infringement. However, despite considering that there is a procedural defect, CLIDOM proceeds to reiterate the following defense arguments presented in the previous written allegations:

Second.- The Initiation Agreement establishes, as a supposed infringement, the possible violation of Article 25 of the GDPR based on the assertion that CLIDOM processed the personal data of the complainant without previously verifying the accreditation of the representation of the person who provided the data, or checking, by any means, that the complainant effectively consented to the change of electricity company or that they consented to the processing of their personal data for that purpose.

The aforementioned article regulates data protection by design and by default, meaning that the data controller must apply, both at the time of establishing the means of processing and at the time of the processing itself, all appropriate technical and organizational measures designed to effectively apply the principles of data protection and integrate the necessary guarantees into the processing to meet the requirements set forth by the GDPR; furthermore, the data controller must apply the aforementioned measures to ensure that, by default, only the personal data necessary for each specific purpose of the processing is processed.

Regarding the possible violation of the principle of data protection by design, while it is true that CLIDOM responds to and identifies with the definitions referred to the data controller in Articles 4 and 24.1 of the GDPR, this is in relation to the contractual relationship that exists with Runup Business SL (hereinafter, "QLIP") for the purposes of the service contract signed with them on August 24, 2021, for the provision of services for promoting electricity supply contracts and attracting potential customers, which is attached for record-keeping purposes as Document number 1. For the fulfillment of the contract, the processing of data of natural persons is required, as QLIP must attract potential customers so that they can register for CLIDOM's energy supply services.

Notwithstanding the above, it is important to emphasize that, in the contract signed between the two parties, CLIDOM, as the data controller, included, as a contractual obligation for QLIP, in its capacity as data processor, the proactive responsibility to collect the consent of the data subjects in accordance with the requirements of the GDPR. Specifically, in clause seven of the contract, titled "obligations of the collaborator," the following is detailed: "(...) In the exercise of its activity, the Collaborator must act loyally and in good faith, safeguarding the interests of Holaluz. Thus, the Collaborator will carry out its activity in accordance with the usual practices of the industry and trade usages, ensuring at all times that the information and advice provided to Potential Clients is truthful and in accordance with the practices."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
8/32

business practices of the highest category. Likewise, Holaluz requires that the Collaborator, being a key ally in the development of the business, adopts behaviors in accordance with the general principles of the Ethical Code. Therefore, by signing this Contract, the Collaborator adheres to Holaluz's Ethical Code and commits to aligning their conduct with the guidelines established therein. Breach of the Ethical Code is considered very serious at Holaluz and will entail the consequences provided for in this Contract." [.....] "In particular, the Collaborator must assume the following obligations for the provision of the Service: (i) To act with the diligence of an orderly businessman in the provision of the Service among Potential Clients, complying with the provisions of this Contract and applicable regulations, especially the regulations of the electricity sector and consumer and user protection laws.

First, the Collaborator commits to providing truthful, clear, and transparent information about Holaluz and its activities so that the consumer is aware of the company with which they are contracting and the

service that will be offered to them. Second, the Collaborator shall refrain from formalizing registrations with Holaluz if the Client has not clearly and unequivocally given their consent for the contracting of the supply with Holaluz. In the case that the client is a non-professional consumer, the Collaborator will ensure that the contracting also complies with consumer and user protection regulations.

Therefore, it is the responsibility of the Collaborator to carry out the necessary checks regarding the identity of the consumer and their willingness to contract, to ensure this. At the same time, Holaluz will conduct random control calls and will contact the client directly without prior notice to the Collaborator to verify that these requirements are being met.”

In accordance with the previous clause, it can be verified that CLIDOM requires QLIP to comply with a series of instructions and good practices for processing the personal data of potential clients in accordance with the GDPR. Furthermore, within the contract itself, the obligations of QLIP as the data processor are outlined. Therefore, to ensure diligence and proper compliance with the instructions imposed on QLIP, CLIDOM has established proactive accountability measures for verifying the collection of valid consents from the interested parties.

Third.- Article 28.4 of the GDPR states the following regarding the obligations of the Data Processor: “When a data processor engages another processor to carry out certain processing activities on behalf of the controller, the same data protection obligations as those stipulated in the contract or other legal act between the controller and the processor referred to in paragraph 3 shall be imposed on this other processor, by means of a contract or other legal act established in accordance with Union or Member State law, in particular the provision of sufficient guarantees to implement appropriate technical and organizational measures in such a way that the processing is in compliance with the GDPR.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/32

provisions of this Regulation. If that other processor fails to comply with its data protection obligations, the initial processor shall remain fully responsible to the data controller for compliance with the obligations of the other processor.”

This last part of Article 28.4 of the GDPR refers to the fact that the processor will be responsible for the processing carried out by its subprocessors, in accordance with the compliance with the obligations of Article 28 of the GDPR. This means that, in the event of non-compliance by the providers selected by the data processor, that is, as in the present case by QLIP, it must take direct responsibility for the actions and/or omissions of its providers, and not, on the contrary, CLIDOM.

Fourth.- In relation to the attribution of responsibilities in this sanctioning procedure, it is important to note that Article 82 of the GDPR, titled “Right to compensation and liability” states in its second paragraph that: “Any controller participating in the processing operation shall be liable for the damages caused in the event that such operation does not comply with the provisions of this Regulation. A processor shall only be liable for the damages caused by the processing when it has not complied with the obligations of this Regulation specifically directed to processors or has acted outside or against the legal instructions of the controller.”

This last paragraph reflects the current case since the subprocessor of QLIP, the real estate company ENFOKA, acted against the instructions of CLIDOM regarding the obligation to obtain the consent of the data subjects as it impersonated the identity of the affected party and, moreover, signed an invalid consent without being able to comply with the principles of transparency, freedom, and explicit consent. Therefore, QLIP is fully responsible for the negligent actions of its provider, due to the non-compliance with Articles 28.4 and 82.2 of the GDPR.

Fifth.- Regarding compliance with the provisions of Article 25.1 of the GDPR, concerning the application of technical and organizational measures to verify the collection of valid consent for the personal data of the data subjects, CLIDOM has a quality and authentication system regarding the identity of its end customers through a review protocol of a significant percentage of new user

registrations, especially when they come from indirect channels to CLIDOM, as is the case in question. In application of this protocol, the internal customer service agents of CLIDOM call by phone to this sample of new customers whose registration has been managed through the indirect channel. Through these calls, CLIDOM aims to ensure the validity of the consent according to the characteristics defined by the GDPR itself and, simultaneously, to verify and demonstrate that the corresponding actions of its processors comply with the law and with the instructions and obligations reflected in the respective contracts with them.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
10/32

Through this quality protocol, CLIDOM has implemented measures for verification and assurance of the actions entrusted to QLIP, thus complying with the principle of proactive responsibility.

Furthermore, in order to comply with the principle of proactive responsibility, QLIP is also requested to provide documentation that certifies that the interested party has consented to the processing of their data for the management of their energy supply contract. In this regard, two emails sent by QLIP are provided as examples, which include the requested documentation, as evidenced by Documents number 2 and 3.

Although, for reasons of volume, not all authorizations are requested, in general terms, CLIDOM conducts an initial audit to verify that the instructions given by it are being followed by its Collaborators, requesting a sample of the authorizations that collect the consent of the interested party, which is fundamental for the continuation of the commercial relationship. Additionally, specific requests are made periodically or whenever an incident is detected, to corroborate that the Collaborator, in this case QLIP, continues to comply with CLIDOM's guidelines. In fact, the collaboration contract itself includes in its Annex III a reference model for third-party representation authorization that CLIDOM's Collaborators can use as a basis, all of which is because it is common practice in the sector for supply holders to delegate the management of their contracting to their energy advisors (see Document Number 1 – Annex III. MODEL AUTHORIZATION FOR THIRD-PARTY REPRESENTATION). Finally, and again to comply with the principle of proactive responsibility, CLIDOM establishes in its Annex IV various measures to control the quality of the services provided by the Collaborators, including the verification of the privacy, security, and confidentiality policies applied by the Collaborators, verification of the security controls applied by the Collaborators to their subcontractors, etc.

Sixth.- CLIDOM has requested from QLIP the documentation related to the commercial relationship it maintains with ENFOKA, as well as the data processing or data transfer contract that governs between the parties, in order to ascertain whether, as a data processor, it has committed to them under the same terms that QLIP is obligated to CLIDOM, given that such obligation is also included in the collaboration contract between the parties. However, as evidenced by the attached emails as Document number 4, QLIP has shown passivity in response to our requests.

Seventh.- It should also be stated that CLIDOM conducts periodic risk analyses to determine those risks that may arise from data processing and, based on the results obtained, design and establish all necessary security measures that are...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
11/32

considered timely to guarantee the rights and freedoms of the interested parties.

Regarding the risk analysis, it has been determined that none of the analyzed risks reach high levels, with the risk levels being moderate. Attached as Document number 5 is the risk analysis related to the "Suppliers" asset conducted on May 19, 2022. Additionally, CLIDOM prepared a report on September 12, 2022, regarding the analysis of the need to conduct an impact assessment, as a mechanism to

ensure that responsibility in privacy is integrated by design in the processing of personal data. The analysis consists of two parts: (i) The first part aims to analyze whether any of the processing activities subject to the analysis fall within the mandatory or excluded cases listed by the supervisory authority and, if not, whether they can be considered high-risk processing, and (ii) Secondly, it will be determined whether the processing should be subject to a DPIA or, on the contrary, whether such an assessment is unnecessary in light of the analysis.

From the first and second-level analysis, it is concluded that the data processing carried out by CLIDOM for the provision of its services indicates that a Data Protection Impact Assessment is not required according to the criteria of the GDPR, the Spanish Data Protection Agency, and the European Data Protection Board. Specifically, from the analyzed assessments, the only positive indicator is related to large-scale processing.

Based on the above, the data processing carried out by CLIDOM DOES NOT NEED TO BE SUBJECT TO AN IMPACT ASSESSMENT. However, given that there is large-scale data processing and considering the nature of CLIDOM's activity, it has been decided to conduct an impact assessment. In the impact assessment conducted on September 15, 2022, concerning customer management, it is concluded that the processing derived from CLIDOM's customer management business processes does not pose a risk that requires prior authorization from the Supervisory Authority to continue processing. However, the security measures proposed in clause 3.5 of the document must be implemented to reduce risks.

Finally, following the completion of the Impact Assessment of the "Customer Management" processing activity of CLIDOM, a series of technical and organizational controls emerged to be implemented due to the identified threats. Therefore, a threat mitigation plan was created on September 22, detailing the controls to be applied to achieve risk minimization.

The three documents are attached as numbers 6, 7, and 8, respectively. Therefore, from the events that occurred, it does not follow, in any case, that CLIDOM has not applied at all times the appropriate technical and organizational measures. Additionally, the following mitigating measures have been adopted subsequent to the receipt of the complaint:

- A data processing agreement has been drafted that regulates in more detail the relationship between the Collaborator and CLIDOM regarding the processing of personal data, even though it was already expressly determined in the Collaboration Agreement (attached as Document number 9).
- The number of control phone calls has been increased for those contracts originating from commercial channels.
- The possibility of automating the mass reading of documents using Artificial Intelligence is being evaluated to verify that the authorizations sent by the commercial channels have been duly completed.
- Improvement and increase in the frequency of control audits of the commercial channels.

Furthermore, among other measures taken to avoid situations that could violate current data protection regulations, training on Data Protection has been conducted for all employees of the company.

Not only is data protection training provided to the entire company, but a data protection and information security session is also included as part of the onboarding sessions for new staff, and employees are kept updated through the sending of newsletters to all workers regarding data protection.

Similarly, the company established a specific email address (lop@clidom.es) to exercise the rights of rectification, cancellation, deletion, limitation of processing, portability, and any rights recognized concerning data processing. Additionally, for any issues related to the functions of the Data Protection Officer, the email address dpd@holaluz.com was established.

Finally, CLIDOM undergoes an annual audit in the area of Data Protection with an external entity and is currently in the process of obtaining ISO 27001 certification for its Information Security Management Systems.

Eighth.- According to FD Third of the Initiation Agreement, the AEPD analyzes a series of elements and criteria to assess the amount of the fine to be imposed.

Without prejudice to our arguments demonstrating CLIDOM's strict compliance with data protection regulations—and therefore that the imposition of the fines indicated in the Initiation Agreement is not warranted—,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
13/32

We also consider it relevant, for the purpose of asserting our right to defense, to make allegations regarding the criteria evaluated by the AEPD.

(i) The scope or purpose of the data processing operation, as well as the affected parties. In this regard, we must highlight that CLIDOM currently has around 300,000 customers and that the present complaint concerns one affected party. We believe that, since it is a single case, this should be taken into account in order to reduce the amount of the sanction. Additionally, considering the circumstances outlined in Article 83.2 of the GDPR, it should be especially noted that there are no previous infringements committed by CLIDOM and that the data processed is not classified as sensitive in any case.

(ii) The intent or negligence of the infringement. In this respect, it should be noted that, as stated in this document, CLIDOM has at all times strictly complied with its obligations regarding data protection. In this line, CLIDOM adopts all appropriate technical and organizational measures for the processing of personal data.

In conclusion, we believe that in light of the aforementioned, the procedure should be automatically archived or, alternatively, the criteria and amounts evaluated should be adjusted.

Ninth.- That, by virtue of all that has been stated and considering it essential to sufficiently argue in defense of the legitimate interests of CLIDOM, under the provisions of Articles 28.4 and 82 of the European Data Protection Regulation, this party REQUESTS.- That, having presented this document, it be admitted, and, by virtue of it, the allegations against the Initiation Agreement be considered timely and properly submitted, and in view of the preceding statements, a resolution be issued whereby, accepting these allegations, the sanctioning procedure No. PS/0680/2022 be archived.”

From the actions taken in this procedure and the information and documentation submitted, the following has been established:

PROVEN FACTS.

First: The existence of a lease contract between the complainant and the real estate agency ENFOKA dated 24/05/21 is evidenced. In this contract and within the contractual obligations of the tenant (the complainant), the payment of electricity consumption is included.

The complainant has contracted this service with the supplier Iberdrola.

Second: In her complaint, she states that on 07/04/22 she noticed a charge of ***AMOUNT.1 euros from another electricity supplier, HOLALUZ, on her bank account, with which she had no contractual relationship, so she contacted them to find out what had happened.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

14/32

From the conversations held with the operators of HOLALUZ, she learned that the electricity contract had been changed to another company on 24/02/22 and that this contract had been signed by a third party, who was an employee of the real estate agency ENFOKA: B.B.B. NIF: ***NIF.2.

It should be noted that the real estate agency ENFOKA is a subcontractor of the entity QLIP, which in turn has a service contract with the electricity company HOLALUZ, and whose mission is to attract new customers for the electric company.

Third: According to the statements made by the real estate agency ENFOKA before this Agency, the tenant was urged on numerous occasions to modify the ownership of the electricity supply, as a mass change of company was being carried out for the electricity contracts of all the homes managed by them. As there was no response from the tenant (the complainant), in February 22, they sent her an email informing her that they would proceed to change the electricity company for the rented property,

communicating her personal data to the company Runup Business, S.L. (QLIP), a company in the commercial channel of HOLALUZ-CLIDOM.

Fourth: According to CLIDOM's statements before this Agency, the subcontractor of QLIP, the real estate agency ENFOKA, acted against CLIDOM's instructions regarding the obligation to obtain the consent of the affected parties, as it impersonated the identity of the affected party and, furthermore, signed an invalid consent without being able to comply with the principles of transparency, freedom, and explicit consent; therefore, QLIP is fully responsible for the negligent actions of its provider.

Fifth: Regarding the technical and organizational measures implemented in the entity CLIDOM, to verify the collection of valid consent for the personal data of the affected parties, it states that the system it has is based on the review of a certain significant percentage of registrations of end users, especially when they come from indirect channels to CLIDOM, as is the case. Although due to volume reasons, control is not performed on all the registration requests received. However, no report or certificate is presented detailing the percentage of calls made for the indicated verifications.

LEGAL GROUNDS

I.-

Competence:

In accordance with the powers granted to each supervisory authority by Article 58.2 of the GDPR, and as established in Articles 47, 48.1, 64.2, and 68.1 of the LOPDGDD, the Director of the Spanish Data Protection Agency is competent to resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/32

in the Regulation (EU) 2016/679, in this organic law, by the regulatory provisions issued in its development and, insofar as they do not contradict them, subsidiarily, by the general rules on administrative procedures."

II.-

Summary of the facts:

According to the claimant in her complaint dated 11/06/22, she has been a tenant of a property since 24/05/21, managed by the real estate agency ENFOKA SISTEMAS GLOBALES, S.L.

As she explains in the complaint, she had contracted the electricity supply with Iberdrola, but on 07/04/22, an amount of ***CANTIDAD.1 euros was charged to her account by an electricity company for the energy supply of the property, of which she had no knowledge and with which she had not contracted anything (HOLALUZ-CLIDOM).

When she contacted the real estate agency ENFOKA, from which she rented the property, to ask them about the reason for this electricity bill, they responded that there had been a mass change for all tenants of the building so that the electricity would be in their name, to which the claimant replied that no one had informed her of this change and much less had she been asked for consent for the change of company, the supply of which, let us remember, she was to pay.

She also reports that, once she obtained the new electricity supply contract with the new company (HOLALUZ-CLIDOM), she realized that her personal data appeared in the "Client" section, but in the section for the signature of the contract, there was a person named "B.B.B." whom she did not know at all.

According to the company CLIDOM, this registration was carried out by the commercial channel Run Up Business SL. (QLIP) with which it maintains a contractual relationship for the registration of new clients and that the real estate agency ENFOKA acted against its instructions regarding the obligation to obtain the consent of the interested parties, as it impersonated the identity of the affected party, and therefore, QLIP is also fully responsible for the negligent actions of its supplier ENFOKA.

Although CLIDOM states that ENFOKA is a subcontractor of QLIP, it does not provide any type of contract that can corroborate this.

CLIDOM also states that, regarding the technical and organizational measures implemented to verify the collection of valid consent for the personal data of the interested parties, the system it has is based on reviewing a certain significant percentage of registrations of end users, especially when they come from indirect channels to CLIDOM, as is the case in question.

However, due to volume reasons, control is not performed on all registration requests received.

Nevertheless, it does not present any type of report or certificate indicating the percentage of calls made for the indicated verifications.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
16/32

III.

Response to the allegations presented:

In relation to the allegations made in the present sanctioning procedure, we proceed to respond to them according to the order presented by the entity:

a).- Response to the allegations presented in point "First" of your written allegations:

Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations -LPACAP-, states in Article 21.1 that the Administration is obliged to issue an express resolution and to notify it in all procedures, regardless of their form of initiation.

However, the proposal for resolution cannot, in any way, be confused with the administrative act of resolving the procedure, as Article 89.2 LPACAP indicates that, in the case of sanctioning procedures, once the instruction of the procedure has concluded, the instructing body will formulate a proposal for resolution directed to the competent body to resolve, which must also be notified to the interested parties, indicating in it the disclosure of the procedure and the deadline for submitting allegations and presenting the documents and information deemed pertinent, establishing in the third section of the aforementioned Article 89 LPACAP that, in it, the facts considered proven and their exact legal qualification will be motivated, the infringement that may exist will be determined, the person or persons responsible, and the sanction that the instructing body proposes, the assessment of the evidence presented, especially those that constitute the basic foundations of the decision, as well as the provisional measures that may have been adopted.

Nevertheless, it is also established that if the competent body to resolve considers that the infringement or the sanction proposed by the instructing body is of greater severity than proposed, it will notify the accused so that they may submit any allegations they deem appropriate within a period of fifteen days, before notifying its decision in the resolution.

Therefore, the proposal for resolution is merely a procedural act that does not determine the conclusion of the procedure, as it is only a proposal made to the body that truly has the competencies for the resolution of the sanctioning procedure, this resolution being the true express administrative act where the procedure is resolved and the sanction is imposed, if applicable.

Thus, the proposal for resolution cannot, in any way, be confused with the administrative act of resolving the procedure, as claimed by the responding party in their allegations, and therefore, there is no "reopening of the sanctioning procedure" in this case, as an express administrative act resolving the procedure and imposing the corresponding sanction or archiving the procedure is still necessary, and this does not occur with the proposal for resolution issued.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
17/32

b).- Response to the allegations presented in the "Second" point of your written submissions:

Regarding the allegations presented in this point, we must recall that Article 4 of the GDPR, under the heading "Definitions," provides as follows:

“2) ‘processing’: any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or any other form of enabling access, alignment, combination, restriction, erasure or destruction.”

“7) ‘data controller’ or ‘controller’: the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of processing, the controller or the specific criteria for its designation may be provided by the law of the Union or of the Member States.”

And that Article 24.1 of the GDPR states, regarding the responsibility of the data controller, that:

“Taking into account the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller shall implement appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is performed in accordance with this Regulation. Such measures shall be reviewed and updated when necessary.”

Well, in the present case, it is established that the entity CLIDOM is the data controller, since, according to the definition in Article 4.7 of the GDPR, it is the one that determines the purposes and means of the processing carried out for the purposes indicated in the documentation provided regarding the contracting of its services, and this is acknowledged in its written submissions.

Therefore, in its capacity as the data controller, it is obliged to comply with the provisions of the transcribed Article 24 of the GDPR, especially concerning the effective and ongoing control of the appropriate technical and organizational measures to ensure and be able to demonstrate that the processing of customer data is in compliance with the GDPR.

For its part, Article 25.1 of the GDPR establishes that:

“Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity that the processing entails for the rights and freedoms of natural persons, the controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/32

data protection, such as data minimization, and integrate the necessary safeguards in the processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects.”

And if we take into account what is stated in the recitals of the GDPR:

74. “The responsibility of the data controller for any processing of personal data carried out by themselves or on their behalf must be established. In particular, the controller must be obliged to implement appropriate and effective measures and must be able to demonstrate compliance of the processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing as well as the risk to the rights and freedoms.”

75. “The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from the processing of data that could cause physical, material, or immaterial harm, particularly in cases where the processing could lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the personal data processed reveal ethnic or racial origin, political opinions, religion or philosophical beliefs, trade union membership, and the processing of

genetic data, data concerning health, or data concerning a person's sex life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, in particular the analysis or prediction of aspects related to work performance, economic situation, health, personal preferences or interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable individuals, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of data subjects.”

76. “The probability and severity of the risk to the rights and freedoms of the data subject must be determined with reference to the nature, scope, context, and purposes of the data processing. The risk must be weighed based on an objective assessment through which it is determined whether the data processing operations pose a risk or if the risk is high.”

In addition to all of this, we must pay attention to what is stipulated in Article 28 of the LOPDGDD, as it indicates that controllers will take into account Articles 24 and 25 for the application of proactive responsibility measures and the greater risks that could arise, including cases of fraud and impersonation:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/32

“Article 28. General obligations of the data controller and processor.

1. The data controllers and processors, taking into account the elements listed in Articles 24 and 25 of Regulation (EU) 2016/679, shall determine the appropriate technical and organizational measures that must be applied in order to ensure and demonstrate that the processing is in compliance with the aforementioned regulation, this organic law, its implementing regulations, and the applicable sectoral legislation. In particular, they shall assess whether it is necessary to carry out a data protection impact assessment and the prior consultation referred to in Section 3 of Chapter IV of the aforementioned regulation.

2. For the adoption of the measures referred to in the previous paragraph, the data controllers and processors shall take into account, in particular, the greater risks that could arise in the following cases:

a) When the processing could generate situations of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic, moral, or social harm to the affected individuals.

b) When the processing could deprive the affected individuals of their rights and freedoms or could prevent them from exercising control over their personal data.

c) When the processing is not merely incidental or accessory to the special categories of data referred to in Articles 9 and 10 of Regulation (EU) 2016/679 and Articles 9 and 10 of this organic law or of data related to the commission of administrative offenses.

d) When the processing involves an evaluation of personal aspects of the affected individuals in order to create or use personal profiles of them, in particular through the analysis or prediction of aspects related to their performance at work, their economic situation, their health, their preferences or personal interests, their reliability or behavior, their financial solvency, their location, or their movements.

e) When the processing of data of groups of affected individuals in a situation of special vulnerability is carried out, particularly minors and persons with disabilities.

f) When mass processing occurs involving a large number of affected individuals or entails the collection of a large amount of personal data.

g) When personal data are to be transferred, on a regular basis, to third countries or international organizations for which an adequate level of protection has not been declared.

h) Any others that, in the opinion of the controller or processor, may be relevant, particularly those provided for in codes of conduct and standards defined by certification schemes.”

It is therefore evident that the data controller, CLIDOM, will be obliged to carry out a risk analysis for the rights and freedoms of individuals, implementing appropriate technical and organizational measures to apply the principles of data protection and integrate the necessary safeguards in the processing in order to comply with the requirements of the GDPR, being able to demonstrate that the processing carried out is in accordance with the provisions of the aforementioned regulation.

The principles of data protection are set out in Article 5 of the GDPR, with particular emphasis on the first of them, relating to the lawfulness of processing, according to which:

“Personal data shall be: a) processed lawfully, fairly, and in a transparent manner in relation to the data subject (‘lawfulness, fairness, and transparency’).”

While the “second” paragraph of the aforementioned Article 5 states that:

“The data controller shall be responsible for compliance with the provisions of paragraph 1 and be able to demonstrate it (‘accountability’).”

Well, from the documentation provided in this procedure and the allegations made by the different parties, it is noted that the real estate company ENFOKA, which manages the property where the complainant lives as a tenant, sent an email to QLIP communicating the tenant's data to change the electricity supply company for the property without ENFOKA informing the tenant about it, and of course, without her consent. Subsequently, QLIP transferred the tenant's data (the complainant) and the data of the person who signed the contract on behalf of the tenant to CLIDOM, proceeding to activate the service.

This entire process was managed without the tenant (the complainant) being informed about it and, of course, was carried out without her consent.

CLIDOM has been stating throughout this procedure that the responsibility for processing the personal data of the complainant lies exclusively with QLIP based on the service contract signed between them and its subcontractor (ENFOKA) since it was the one that initially carried out the unauthorized data processing of the complainant, but it does not provide any type of contract between the companies that could corroborate its allegations, so it should be considered mere statements without any documentary support.

Furthermore, it has been observed that when the service is contracted through an alleged representative of the new client, CLIDOM does not require that the representation claimed be accredited, evidencing that CLIDOM does not have an efficient system in place to verify that clients registered through an alleged representative have given their consent for it.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
21/32

CLIDOM defends itself by alleging that it has implemented a review protocol for a certain percentage of user registrations when such registrations come through external collaborators, as is the case here. However, as confirmed by the entity itself, due to volumetric reasons, this is not carried out on all requests but rather on a certain percentage, which is not specified, as it does not present any report or certificate that could corroborate the percentage of calls made.

It is evident that conducting a random sample control of registrations can generate risks in the processing of personal data of customers, such as the processing of data without legitimization, or the risk of identity theft for the commission of fraud, with the economic and social harms that this entails. CLIDOM alleges that it is the responsibility of its collaborator QLIP to carry out the relevant checks regarding the identity of the consumer and their willingness to contract, to ensure this, and indicates that, nevertheless, CLIDOM will carry out random control calls and directly contact the customer to verify consent.

It should be noted that the stipulations of Articles 24 and 25 of the GDPR refer to the obligations established for the data controller. Thus, Article 24 establishes the obligation for the controller to apply appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is in accordance with the GDPR, and Article 25 reiterates the obligation of the controller to apply, both at the time of determining the means of processing and at the time of the processing itself,

appropriate technical and organizational measures to comply with the requirements of the GDPR and protect the rights of each and every data subject, and not just a certain randomly chosen percentage, as CLIDOM does.

Therefore, it is the ultimate data controller, in this case CLIDOM, who must implement the necessary technical and organizational measures for the proper processing of personal data, in compliance with its proactive accountability obligations, as expressed in Articles 24 and 25 of the GDPR, or as indicated in the terms of Recital 73: "the controller shall be obliged to implement appropriate and effective measures and must be able to demonstrate compliance of the processing activities with this Regulation, including the effectiveness of the measures," and therefore, it is the ultimate data controller who is responsible for ensuring that such measures are complied with.

CLIDOM should have assessed the risks and in particular the risks of Article 28 in its risk analysis and impact assessment, but from the documentation provided, there is no evidence that this has been done. It indicates that it carries out mass data processing, and also conducts solvency assessments as derived from the Contract between CLIDOM and QLIP, in which it is stated that the processor will collect "Solvency information, in accordance with the solvency assessment procedures established by Holaluz at any given time." However, these risks have not been assessed nor have measures been adopted to mitigate them. Therefore, it is relevant here that the respondent has not made any assessment regarding the risk of identity theft or fraud, making it difficult to adopt appropriate measures; it cannot be assessed whether the measure of conducting random checks is sufficient.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
22/32

Random calls to verify the truthfulness of the hiring are appropriate when the risk has not even been assessed.

c).- Response to the allegations presented in points "Third" and "Fourth" of your written allegations: In these points, it should be made clear that the present sanctioning procedure does not address the possible responsibility of the data processor (QLIP) for the potential non-compliance in the processing of the claimant's personal data by the real estate company ENFOKA, as established in Article 28 of the GDPR, but rather the responsibility of the ultimate data controller (CLIDOM), based on what is stipulated in Article 25 of the GDPR, since it has been established that, when the service contract was changed in the name of the tenant (claimant), CLIDOM did not carry out any verification regarding the claimant's consent to the change of electricity company, especially considering that the contract for the change of supply was signed by a person unrelated to the claimant and that there was no indication in that contract that could support this person's representation on behalf of the claimant.

In this regard, the doctrine of the National Court indicates that when the data subject denies consent for the processing of their data, the burden of proof falls on the one who asserts its existence, and the data controller must gather and retain the necessary documentation to prove that consent has been given and that it has been given by the data subject (National Court Judgment of May 31, 2006.- Rec. 539/2004): "On the other hand, it is the data controller (see, among others, judgment of this Chamber of October 25, 2002 Rec. 185/2001) who is responsible for ensuring that the person from whom consent is requested actually gives it, and that this person giving consent is indeed the holder of those personal data, and must retain proof of compliance with the obligation available to the Administration."

d).- Response to the allegations presented in point "Fifth" of your written allegations:

Well, as we have been indicating throughout the entire procedure, Article 25 of the GDPR establishes the obligation for the data controller to apply, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures that ensure compliance with the requirements of the GDPR and thus, the protection of the rights and freedoms of the data subjects.

This article has as its antecedent Article 24 of the GDPR which states that, "Taking into account the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller shall implement appropriate

technical and organizational measures to ensure and be able to demonstrate that the processing is performed in accordance with this Regulation.”

In line with these provisions, Recital 78 of the GDPR indicates that:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/32

"The protection of the rights and freedoms of natural persons with respect to the processing of personal data requires the adoption of appropriate technical and organizational measures in order to ensure compliance with the requirements of this Regulation. In order to demonstrate compliance with this Regulation, the data controller must adopt internal policies and implement measures that particularly comply with the principles of data protection by design and by default. Such measures may consist, among others, of minimizing the processing of personal data, pseudonymizing personal data as soon as possible, providing transparency regarding the functions and processing of personal data, allowing data subjects to monitor the processing of data, and enabling the data controller to create and improve security elements. When developing, designing, selecting, and using applications, services, and products that are based on the processing of personal data or that process personal data to fulfill their function, producers of products, services, and applications should be encouraged to take into account the right to data protection when developing and designing these products, services, and applications, and to ensure, with due regard to the state of the art, that data controllers and processors are in a position to fulfill their obligations regarding data protection. The principles of data protection by design and by default should also be taken into account in the context of public contracts."

Therefore, the principle of data protection by design is the key to be followed by the data controller to demonstrate compliance with the GDPR, as they are required to adopt internal policies and implement the necessary measures that ensure compliance with the principles of data protection by design and by default.

Thus, regarding the risks that may be present in the processing, the data controller must carry out an exercise of analysis and detection of risks throughout the entire data processing cycle, with the ultimate aim of protecting the rights and freedoms of all data subjects, and not only when the processing actually occurs. This is expressed in the Guidelines 4/2019 of the European Data Protection Board (EDPB) regarding Article 25 Data protection by design and by default, adopted on October 20, 2020, stating in this regard:

"35. The 'moment of determining the means of processing' refers to the period of time in which the controller is deciding how the processing will be carried out and how it will occur, as well as the mechanisms that will be used to carry out such processing. In the process of making such decisions, the data controller must assess the appropriate measures and safeguards to effectively apply the principles and rights of data subjects in the processing, and take into account elements such as risks, the state of the art, and the cost of implementation, as well as the nature, scope, context, and purposes. This includes the moment of acquiring and implementing software and hardware and data processing services.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/32

36. Taking into consideration the PDDD (data protection by design and by default) from the outset is crucial for the proper application of the principles and for the protection of the rights of the data subjects. Furthermore, from a cost-effectiveness perspective, it is also in the interest of the data controllers to consider the PDDD as early as possible, as it may later prove difficult and costly to introduce changes to already formulated plans and designed processing operations.

To this end, when designing the processing, one must refer to the principles set out in Article 5 of the GDPR, which will serve to assess the effective compliance with the GDPR. Thus, the aforementioned

Guidelines 4/2019 of the EDPB state that “61. To make the PDDD effective, data controllers must apply the principles of transparency, lawfulness, fairness, purpose limitation, data minimization, accuracy, storage limitation, integrity and confidentiality, and proactive responsibility. These principles are laid down in Article 5 and Recital 39 of the GDPR. (...)”

The Privacy by Design Guide from the AEPD states that “Privacy by design (hereinafter, PbD) involves using a risk management and proactive responsibility approach to establish strategies that incorporate privacy protection throughout the entire lifecycle of the object (whether it is a system, a hardware or software product, a service, or a process). The lifecycle of the object refers to all the stages it goes through, from its conception to its withdrawal, including the phases of development, production, operation, maintenance, and withdrawal.”

The Guide also states that, “Privacy must be an integral and inseparable part of systems, applications, products, and services, as well as of the business practices and processes of the organization. It is not an additional layer or module that is added to something pre-existing, but must be integrated into the set of non-functional requirements from the very moment it is conceived and designed (...) Privacy is born in the design, before the system is operational, and must be guaranteed throughout the entire lifecycle of the data.”

Therefore, privacy by design, an obligation of the data controller that arises before the system is operational, is not a patch used to resolve an incident detected in the system.

The risk-based approach refers directly and immediately to a preventive system aimed at visualizing, concerning the processing of personal data, the risks to the rights and freedoms of natural persons. Risks must be identified, their impact assessed, and the likelihood of their occurrence evaluated. Thus, it is not the data that is protected, but the individuals behind it.

The risks to the rights and freedoms of natural persons arising from the processing of personal data can vary in severity and likelihood and can cause physical, material, or immaterial harm, tangible or intangible consequences, to the rights and freedoms of natural persons. Recital 75 of the GDPR and Article 28.2 of the LOPDGDD exemplify some of these, but they are not the only ones. It will depend on the processing and the context in which it occurs.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/32

regarding the personal data processed, of the individuals involved or the means used:

“(75) The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from the processing of data that could cause physical, material, or immaterial harm, particularly in cases where the processing may lead to issues of discrimination, identity theft, or fraud, financial losses, (...)”.

From the content of the documentation in the file, it is evident that the origin of the incident lies in a poor design of the system implemented by the entity CLIDOM for verifying the consent provided by the holder of the registration contract when such contract is signed by an alleged representative of the same, as the entity itself confirms that only a sampling of new registrations is conducted to verify the authenticity of the consent, since, according to the entity itself, “due to volume reasons, control is not performed on all the registration requests received.”

Article 25 of the GDPR is not limited to ensuring adequate security relative to the risk, implementing random verification and assurance measures, as stated by the entity CLIDOM, but rather to the adoption of measures that guarantee the effective application of data protection principles and compliance with the requirements of the GDPR to protect the rights of each and every data subject. This is not only through security measures but also through all types of appropriate technical or organizational measures.

It should be noted that Data Protection by Design and by Default (DPbDD) is a legal obligation, the breach of which constitutes an infringement as provided in Article 83 of the GDPR. Data protection by design is part of the compliance management system, which involves conceiving and planning the processing, verifying compliance, and being able to demonstrate it, all framed within a process of

continuous review and improvement.

In the present case, the lack of design of the processing by the entity CLIDOM is evident, since, as it itself acknowledges, it only conducts a sampling of the registrations received from external collaborators to verify whether there has truly been valid consent from the new clients.

e).- Response to the allegations presented in point "Seventh" of its written allegations:

The responding party indicated in its written allegations, regarding the performance of the personal data impact assessment (DPIA), that "on September 12, 2022, it prepared a report on the analysis of the need to conduct an impact assessment, as a mechanism to ensure that responsibility in privacy by design in the processing of personal data, and that from the analysis it is concluded that the data processing carried out by CLIDOM for the provision of its services determines that a Data Protection Impact Assessment is not required according to the criteria of the GDPR, the AEPD, and the European Data Protection Board, but that, given there is large-scale data processing and,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/32

Considering the nature of CLIDOM's activity, it has been decided to carry out an impact assessment. In the impact assessment conducted on September 15, 2022, it was concluded that the treatments derived from CLIDOM's customer management business processes do not pose a risk that requires prior authorization from the Control Authority to continue the treatment. However, the security measures proposed in clause 3.5 of the document must be implemented to reduce risks, such as, for example, increasing control phone calls for those contracts that come from commercial channels or the possibility of automating the mass reading of documents through Artificial Intelligence in order to verify that the authorizations sent by the commercial channels have been completed.

Firstly, it is necessary to highlight that at the time of the filing of the complaint that led to the present sanctioning procedure, that is, on June 12, 2022, as confirmed by the complained party, the study on the need for an impact assessment had not even been conducted, as it was carried out on September 12, 2022.

Secondly, although the present sanctioning procedure has not evaluated the possible violation of what is stipulated in Article 35 of the GDPR regarding the obligation to carry out a Data Protection Impact Assessment (DPIA), it is necessary to state regarding the allegations presented by CLIDOM that, in general, there is an obligation to carry out a DPIA whenever the treatment involves a high risk to the rights and freedoms of natural persons.

The GDPR dedicates Section 3 of its Chapter IV "Controller and Processor" to the Data Protection Impact Assessment (DPIA). Specifically, paragraph 1 of Article 35 establishes, in general terms, the obligation that data controllers have to carry out a DPIA prior to the implementation of such treatments when it is likely that they, by their nature, scope, context, or purposes, entail a high risk to the rights and freedoms of natural persons, a high risk that, according to the Regulation itself, will be increased when treatments are carried out using "new technologies."

To assist data controllers in identifying those treatments that require a DPIA, the GDPR provides that the supervisory authorities must publish a list of treatments that require a DPIA. This list must be communicated to the European Data Protection Committee (EDPC).

The complained party has stated that, initially, the DPIA was not carried out because it does not fall under any of the cases that require it, according to Article 35 of the GDPR. However, we are not dealing with an exhaustive list; rather, the complexity of the risk management process must be assessed, taking into account not the size of the entity, the availability of resources, or its specialty or sector, but the possible impact of the treatment activity on the data subjects.

Thus, the aforementioned list is based on the criteria established by the Article 29 Working Party in the WP248 guidelines "Guidelines on Data Protection Impact Assessment."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
27/32

the protection of data (EIPD) and to determine whether the processing "likely entails a high risk" for the purposes of the GDPR", and should be understood as a non-exhaustive list, highlighting, for the case at hand, the data processing that,

"(7.) involves the use of data on a large scale."

In this case, a GDPR risk analysis must be conducted to identify the risks that may arise from the data processing and to assess the likelihood and impact of materialization, in order to determine the level of risks and whether they are tolerable, can be minimized or eliminated, or are unacceptable.

Moreover, and without prejudice to the treatments listed in the non-exhaustive list of the AEPD, the controllers must assess whether it is appropriate to carry out an impact assessment regarding the treatments they perform, taking into account, among others, the risks outlined in Article 28 of the LOPDGDD.

It should be noted that the risks can be of two types: - risks that affect the individuals whose data is processed and that can materialize in the violation of their rights and freedoms, loss of necessary information, or damages caused by the unlawful or fraudulent use of the data, and risks that may affect the company or organization for not having implemented an adequate and sufficient data protection policy.

Once the risks have been analyzed, measures must be established to address them. That is to say, guarantees must be established based on them through which the protection of personal data is ensured, as well as ensuring that all procedures strictly comply with the regulations (GDPR), always keeping in mind the rights and legitimate interests of each and every one of the data subjects and other affected persons.

These measures should aim to eliminate, mitigate, or transfer the detected risks. Generally, impact assessments also include the acceptance of the detected risks, but in data protection and regarding how the rights and freedoms of individuals may be impacted, acceptance could imply a breach of the regulations, so the measures to be implemented must always be aimed at avoiding or eliminating those risks. Another matter is that, after having implemented a system that seeks the total elimination of the risk, it occurs, in which case a review of the method must be carried out to adapt it with the ultimate goal of eradicating the risk.

Therefore, the proposed measures, such as increasing the number of control phone calls for those contracts that come from commercial channels, do not demonstrate that the aim is to reduce the risk to zero, as neither the risk of impersonation and fraud has been assessed nor is the percentage of calls to be made on the total number of registration requests received from external channels detailed.

f).- Response to the allegations presented in point "Eighth" of your written allegations:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
28/32

In this section, the entity being claimed against states that it has approximately 300,000 clients and that the present claim concerns only one affected party. It asserts that there are no prior infringements committed by CLIDOM and that the data processed does not fall under any circumstances as sensitive. Furthermore, it states that it has at all times strictly complied with its obligations regarding data protection, adopting appropriate technical and organizational measures for the processing of personal data.

The present sanctioning procedure was initiated due to the fact that the claimed party processed the personal data of the claimant without previously verifying the accreditation of the representation of the person who provided the data, or confirming, by any means, that the claimant effectively consented to change the electricity company, as stipulated in Article 25 of the GDPR.

This infringement may be sanctioned with a fine of up to €10,000,000 or, in the case of a company, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount, in accordance with Article 83.4.a) of the GDPR.

To determine the sanction, the provisions of Articles 83.1 and 2 of the GDPR, and 76 of the LOPDGDD must be taken into account, and it was deemed appropriate to apply as aggravating factors for calculating the sanction to be imposed, the potentially affected clients, in accordance with the Guidelines 4/2022 of the EDPB on the calculation of administrative fines under the GDPR, in its version of May 12, 2022, which was then subject to public consultation, with the initial sanction imposed being well below the maximum established in the GDPR.

Furthermore, it was taken into account that the business activity of the claimed party necessarily involves the processing of personal data. This characteristic of its business activity impacts, reinforcing it, the diligence that must be exercised in complying with the principles governing the processing of personal data and the quality and effectiveness of the technical and organizational measures that must be implemented to ensure respect for the fundamental right.

Therefore, it must be considered what was established by the National Court in this case (SAN of October 17, 2007 (rec. 63/2006):

"...the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. In assessing the degree of diligence, special consideration must be given to the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, there must be an insistence on rigor and exquisite care to comply with the legal provisions in this regard." Therefore, if we adhere to the jurisprudence of the Supreme Court, we could even consider this section as a qualified aggravating factor, given the lack of due diligence in this case regarding the management of personal data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/32

Therefore, in consideration of all the above, the request of the entity being claimed to reduce the imposed sanction of 100,000 euros cannot be granted in this case.

IV.-

Administrative Infraction

In the present case, it is evident that the entity HOLALUZ-CLIDOM, S.A., is responsible for the data processing referred to in the background, since, according to the definition in Article 4.7 of the GDPR, it is the one that determines the purpose and means of the data processing carried out concerning the contracting of its services, that is, registering a new customer and managing the electricity supply to their home or business, regardless of the channel through which the data was obtained; in this case, as stated, it was obtained through the commercial channel Run Up Business SL, with which HOLALUZ-CLIDOM maintains a contractual relationship for this purpose.

In short, the data controller is the natural or legal person or public authority that decides on the processing of personal data, determining the purposes and means of such processing. By virtue of the principle of proactive responsibility, the data controller must apply technical and organizational measures to comply with and be able to demonstrate compliance, taking into account the risk involved in the processing of personal data.

Therefore, the aforementioned facts constitute a violation of the principle of data protection by design regulated in Article 25 of the GDPR, which leads to the application of the corrective powers granted to the Spanish Data Protection Agency by Article 58 of the aforementioned Regulation.

The fact that the entity being claimed processed the personal data of the claimant without previously verifying the accreditation of the representation of the person who provided the data, or without checking, by any means, that the claimant effectively consented to the change of electricity company or that they consented to the processing of their personal data for that purpose, constitutes an infringement of Article 25.1) of the GDPR.

This infraction may be sanctioned with a fine of up to €10,000,000 or, in the case of a company, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount, in accordance with Article 83.4.a) of the GDPR.

For its part, Article 73.d) of the LOPDGDD considers “serious,” for the purposes of prescription, “The failure to adopt those technical and organizational measures that are appropriate to effectively apply the principles of data protection by design, as well as the non-integration of the necessary guarantees in the processing, in the terms required by Article 25 of Regulation (EU) 2016/679.”

V.-

Graduation of the Sanction

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30/32

The determination of the sanction to be imposed in the present case requires observing the provisions of Articles 83 of the GDPR and 76 of the LOPDGDD, and in accordance with these provisions, for the purpose of setting the amount of the fine to be imposed on the entity being claimed. The following factors are deemed concurrent in this case:

As aggravating factors:

- The scope or purpose of the data processing operation, as well as the affected parties in relation to the number of potential affected parties (paragraph a of Article 83.1 GDPR).
- The intentionality or negligence of the infringement by the entity (paragraph b of Article 83.1 of the GDPR).

It is also considered appropriate to graduate the sanction to be imposed according to the following aggravating criteria established by Article 76.2 of the LOPDGDD:

- The link of the infringer's activity with the carrying out of personal data processing (paragraph b), considering that the activity being developed involves the personal data of its customers.

Considering the factors presented, the assessment of the final fine for the infringement of Article 25 of the GDPR is €100,000 (one hundred thousand euros).

VI.-

Measures

Article 58.2 of the GDPR establishes the corrective powers available to a supervisory authority, and paragraph d) of the cited provision establishes that it may consist of “ordering the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, when appropriate, in a specific manner and within a specified time frame.”

Therefore, it is appropriate to impose the corrective measure described in Article 58.2.d) of the GDPR and order the entity HOLALUZ-CLIDOM, S.A. to establish, within six months, the appropriate technical and organizational measures to verify the consent allegedly given by the new customers of the company and/or the veracity of the alleged representatives of the same.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Data Protection Agency

RESOLVES:

FIRST: TO IMPOSE on the entity HOLALUZ-CLIDOM, S.A., CIF: A65445033, for the infringement of Article 25 of the GDPR, classified in Article 83.4.a) of the GDPR, a sanction of €100,000 (one hundred thousand euros).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/32

SECOND: TO ORDER the entity HOLALUZ-CLIDOM, S.A., CIF: A65445033 to implement, within a

period of six months, the appropriate technical and organizational measures to verify the consent allegedly given by the new customers of the company and/or the veracity of the alleged representatives of the same.

THIRD: TO NOTIFY this resolution to HOLALUZ-CLIDOM, S.A.

FOURTH: To warn the sanctioned party that the imposed sanction must be enforced once this resolution becomes executive, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, within the voluntary payment period indicated in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by depositing it into the restricted account No. ES00 0000 0000 0000 0000 0000, opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., or otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once it is executive, if the date of executiveness falls between the 1st and the 15th of each month, both inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, both inclusive, the payment deadline will be until the 5th of the second following month or the next business day. In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative route (Article 48.6 of the LOPDGDD), and in accordance with the provisions of Articles 112 and 123 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may optionally file a motion for reconsideration with the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned legal text.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the firm resolution in the administrative route may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronicaweb/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/32

They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es